ITSX25 Kurs 6

Individuell inlämningsuppgift

Workshop 2 - MITRE ATT&CK och hotanalys

Syfte
Denna individuella inlämningsuppgift följer upp Workshop 2 och tränar förmågan att använda MITRE ATT&CK, TTP, defensiv hotanalys, attackkedjor, försvarsfrågor, källor, spårbarhet och koppling till projektarbete.

Viktig avgränsning
Uppgifterna ska användas för analys, dokumentation och försvar. Beskriv inte tekniska genomförandesteg för angrepp. Fokusera på vad ett säkerhetsteam behöver förstå, upptäcka, förhindra och följa upp.

Instruktion till studenten

- Uppgiften genomförs individuellt och lämnas in enligt lärarens instruktion i Canvas.
- Uppgiften täcker kursmål 1, 2, 6 och 11.
- Du får använda materialet från Workshop 2, MITRE ATT&CK, kursmaterial och egna anteckningar.
- Du får använda generativa AI-assistenter och AI-assisterade säkerhetsverktyg, dock ska du beskriva eventuell AI-användning och vad som kontrollerats manuellt.
- Fokusera på tydliga resonemang, spårbarhet och defensiv analys.
- Dina svar ska visa att du kan använda begreppen, inte bara återge definitioner.
- Om du är osäker: skriv vad du är osäker på och hur du skulle följa upp det.

Översikt

Del	Fokus	Uppgifter
Del 1	Förstå MITRE ATT&CK som analysramverk	1-4
Del 2	TTP: Tactic, Technique och Procedure	5-8
Del 3	Bygg en defensiv attackkedja	9-12
Del 4	Försvarsfrågor och Blue/Purple-perspektiv	13-16
Del 5	Källor, spårbarhet och kvalitet	17-20
Del 6	Koppling till backlog, sprint och Workshop 3	21-24

Del 1 - Förstå MITRE ATT&CK som analysramverk

Uppgift 1

Beskriv med egna ord vad MITRE ATT&CK används till i ett säkerhetsteam.

Svarsinstruktion: Skriv 150-250 ord. Fokusera på analys, språk, struktur och försvarsperspektiv.

Vi kan börja med vad MITRE ATT&CK står för vilket är "Adversarial Tactics, Techniques och Common Knowledge".

Dess roll i ett säkerhetsteam varierar helt från hur mycket teamet förlitar sig på verktyget MITRE ATT&CK, man kan utföra gap analyser som visar sårbarheter i sitt egna försvar genom att välja ut attack mönster som är relevanta för IT-miljön de arbetar i kan man snabbt skapa eventuella attackkedjor man kan stärka upp skyddet för och skapa en större bild av attackytan samt skapa en klarare bild vid incidenter för att analytiker kan utgå från en logisk mall som underlättar för personer att förmedla samt förstå incidenten snabbare.

Detta ramverk hjälper som sagt att förstå IT-säkerhetsincidenter vilket är till stor nytta om aktör hotar IT världen så kan man förstå hur deras attacker ser ut på ett mer strukturerat sätt vilket leder till att man snabbt kan skydda sig genom att följa ramverket

Uppgift 2

Förklara varför ATT&CK inte ska användas som en checklista för att “göra attacker”.

Svarsinstruktion: Skriv 150-250 ord. Beskriv skillnaden mellan analysramverk och angreppsinstruktion.

MITRE ATT&CK bör inte användas som en checklista eller instruktion för att genomföra attacker, eftersom ramverket helt saknar det praktiska och tekniska djup som krävs för att faktiskt utnyttja sårbarheter i en IT-infrastruktur. ATT&CK är i grund och botten ett analysramverk. Dess primära syfte är att kartlägga vad en angripare vill uppnå och hur de teoretiskt går tillväga, för att hjälpa försvarare att identifiera attackmönster, förstå hotbilden och proaktivt stärka upp sitt skydd. Ramverket förklarar beteenden, men levererar varken skripten eller koden för att exekvera dem.

För den som behöver faktiska angreppsinstruktioner är offensiva verktyg som Metasploit mer relevanta i sammanhanget. Metasploit innehåller den faktiska koden, specifika exploits och aktiva funktioner som hjälper en aktör att faktiskt bryta sig in i system och etablera kontroll. Det är designat just för att utföra attacker och skapa de realistiska scenarion som äkta cyberattacker följer. Förenklat kan man säga att Metasploit är verktyget som används för att utföra inbrottet, medan ATT&CK är den strukturerade utredningen som hjälper försvararna att förstå metoden och blockera vägen in.

Uppgift 3

Välj fem tactics från Enterprise Matrix och beskriv vad varje tactic betyder på en övergripande nivå.

Svarsinstruktion: Använd egna ord. Undvik tekniska genomförandedetaljer.

Intial Access: Det är fasen där angriparen kommer in i IT-systemet för första gången, det är ett av de mest kritiska taktikerna som försvarande förmåga måste stärka sig mot hela tiden.

Persistence: När angriparen väl är inne i systemet så vill man inte bli påkommen direkt, därför lägger en angripare stor vikt på att kunna vara inne i systemen under längre perioder för att kunna förstå sig på it-miljön och för att sedan kunna sprida sig vidare och sätta rötterna djupare.

Privilege Escalation: För att en angripare ska kunna få fäste i en it-miljö och kunna utföra obehörig

åtkomst så måste denne ha en taktik för att skaffa sig mer behörigheter i systemen vilket kan nås med hjälp av att stänga av säkerhetsprogram och knäcka konton som har högre behörigheter.

Lateral movement: Angriparen börjar oftast vid en dator som har en sårbarhet öppen mot internet och efter att stannat i it-miljön tillräckligt länge för att förstå hur den är utformad så kan angriparen påbörja sin resa inom nätverket genom att flytta sig till andra enheter genom att kommit åt högre behörighet eller andra sårbarheter.

Exfiltration: Oftast så är syftet för angriparen ekonomiskt och då kräver det ibland att de måste stjäla affärskritiska hemligheter eller annan viktig data för att tjäna på sitt angrepp och då behöver de kunna smyga ut data från nätverket obemärkt vilken denna taktik förklarar.

Uppgift 4

Beskriv hur ATT&CK kan stödja kommunikationen mellan red team, blue team och ledning.

Svarsinstruktion: Skriv 200-300 ord. Ta upp gemensamt språk, spårbarhet och prioritering.

MITRE ATT&CK fungerar som ett verktyg för att ena olika ansvarsområden inom en organisation kring den faktiska hotbilden. I komplexa IT-miljöer är kommunikation ofta den största utmaningen, och ramverket löser detta genom att erbjuda ett standardiserat, gemensamt språk. När en säkerhetsincident inträffar behöver de olika IT-avdelningarna inte längre trassla in sig i teknisktinvecklat snack eller unika verktygsnamn. Genom att direkt referera till matrisens tekniker vet alla inblandade exakt vilket attackbeteende som diskuteras, vilket minskar missförstånd och kortar ner reaktionstiderna drastiskt.

Denna brygga är lika avgörande för förståelsen hos organisationens mindre tekniska roller, såsom ledningsgrupp och beslutsfattare. När ett angrepp ska förklaras gör ramverket det möjligt att lyfta blicken från obegripliga nätverksloggar till tydliga, logiska attackmönster. Genom att utföra och presentera visuella gap-analyser utifrån matrisen kan säkerhetsteamet visa exakt var försvaret är starkt och vilka delar av attackytan som måste prioriteras. Det förvandlar abstrakta sårbarheter till konkreta, begripliga affärsrisker för ledningen.

Utöver kommunikationen tillför ramverket en spårbarhet i det operativa säkerhetsarbetet, inte minst i samspelet mellan olika säkerhetsfunktioner. Medan ett Red Team fokuserar på det kreativa utförandet av attacken för att penetrera IT-miljön, använder Blue Team ramverket som en mall för att dekonstruera händelsen. Istället för att bara konstatera att de blev hackade, kan försvararna följa spåren bakåt steg för steg. De kan identifiera exakt i vilken fas larmen uteblev, isolera svagheterna i arkitekturen och logiskt täppa igen de specifika säkerhetshål som tillät Red Team att nå sitt mål.

Del 2 - TTP: Tactic, Technique och Procedure

Uppgift 5

Förklara skillnaden mellan tactic, technique och procedure.

Svarsinstruktion: Använd ett eget defensivt exempel. Håll dig på konceptuell nivå.

Skillnaden mellan taktik, teknik och procedur (TTP) beskriver de olika nivåerna av en attack. För ett säkerhetsteam är det helt avgörande att förstå dessa nivåer för att veta var de ska fokusera sitt försvar

Taktik (Varför): Angriparens strategiska mål. Vad försöker de uppnå i just detta skede av attacken?

Teknik (Hur): Den övergripande metoden angriparen väljer för att nå sitt mål.

Procedur (Med vad): Den exakta implementeringen, kommandot eller verktyget som används rent praktiskt.

Exempel:

Tänk dig att en angripare vill se till att de inte förlorar åtkomsten till ett system ifall användaren startar om sin dator.

Taktiken är Persistence (Uthållighet). Deras mål är att överleva en omstart.

Tekniken de väljer är att skapa en Schemalagd aktivitet. Metoden går ut på att be operativsystemet starta angriparens kod automatiskt.

Proceduren är det specifika namnet och kommandot de använder t.ex. att lägga in en skadlig fil döpt till "system_update.exe" som är inställd på att köras kl. 08:00 varje morgon.

Försvaret ska istället bygga sin övervakning kring tekniken som att till exempel skapa en larmregel i sitt SIEM som varnar så fort en okänd schemalagd aktivitet skapas, oavsett vad filen heter eller vilken tid den ska köras detta tvingar då de angriparen att byta hela sin teknik.

Uppgift 6

Skapa en TTP-förklaring för tre valfria ATT&CK-tekniker.

Svarsinstruktion: För varje teknik: skriv tactic, technique och en kort procedure-beskrivning utan operativa instruktioner.

Nätverksbaserad filöverföring:

Tactic: Command and Control

Technique: Ingress Tool Transfer (T1105)

Procedure: Angriparen använder operativsystemets inbyggda verktyg för att hämta sin skadliga kod från en extern server, för att kringgå larm om okända externa program. Ett operativt utförande är att öppna en osynlig kommandotolk och köra kommandon via PowerShell för att tyst ladda ner filen till disken.

Stöld av lösenord från ram:

Tactic: Credential Access

Technique: OS Credential Dumping: LSASS Memory (T1003.001)

Procedure: För att extrahera inloggningsuppgifter och hash-värden kopierar angriparen minnet från den Windows-processen LSASS. Rent operativt utnyttjas ofta Microsofts legitima felsökningsverktyg Sysinternals Procdump. Angriparen öppnar en kommandotolk som administratör och kör ett kommando som dumpar en del av minnet. Den skapade dumpen av ram exfiltreras sedan för att knäckas offline med cracking verktyg.

Automatisk exekvering via schemaläggning:

Tactic: Persistence

Technique: Scheduled Task/Job: Scheduled Task (T1053.005)

Procedure: För att systemet automatiskt ska starta angriparens bakdörr efter en omstart, skapas en falsk schemalagd aktivitet som smälter in bland vanliga systemuppdateringar. Den operativa instruktionen utförs via Windows kommandotolk. Kommandot tvingar datorn att starta den skadliga filen

med högsta systembehörighet varje gång en användare loggar in.

Uppgift 7

Välj en tactic och identifiera tre tekniker som kan höra hemma inom den.

Svarsinstruktion: Motivera varför teknikerna passar in i tacticen.

Taktik: Initial Access

3st tekniker som passar in:

Nätfiske (Phishing - T1566):

Angriparen skickar falska mejl med virusbelagda filer eller länkar till personalen.

Utnyttja publika applikationer (Exploit Public-Facing Application - T1190):

Angriparen letar efter och tillslut utnyttjar sårbarheter i system som är direkt exponerade mot internet, till exempel en webbserver eller en inloggningsportal.

Använda giltiga konton (Valid Accounts - T1078):

Angriparen köper, gissar eller knäcker lösenord som tillhör befintliga anställda för att logga in via exempelvis företagets VPN

Uppgift 8

Beskriv varför det kan vara svårt att mappa en observation till rätt teknik.

Svarsinstruktion: Ta upp osäkerhet, kontext, datakvalitet och behov av källor.

Kontext: Det är väldigt svårt att direkt förstå en angripares mål med en attack, en logg visar vad som skedde men inte vad det kan leda till. Om man t.ex. ser misstänka kommandon upptäckas kan det lika gärna vara en IT-tekniker som håller på med konfiguration. Så kontext är viktigt vid mappning till rätt teknik

Bristande datakvalitet:

För att identifiera exakt teknik krävs hög detalj i loggarna. Om övervakningssystemet bara registrerar att processen powershell.exe startade, men saknar förmågan att spara de specifika argumenten som skrevs i terminalen, stannar analysen upp.

Inbyggd osäkerhet:

Avancerade angripare döljer aktivt sina spår. Skript obfuskeras, skadlig kod injiceras i minnet på legitima program och trafik krypteras. När du utreder en dold process är det vanligt att du måste hantera en hög grad av osäkerhet. Du kanske bara kan bekräfta att systemet manipulerats, medan den sanna tekniken förblir okänd.

Behovet av flera källor:

En enskild loggrad målar sällan hela bilden. Om ett konto loggar in via VPN från en ovanlig plats kan det vara Valid Accounts (T1078), men det kan också vara en anställd på tjänsteresa. För att säkerställa rätt teknik måste du kombinera data från flera olika källor.

Del 3 - Bygg en defensiv attackkedja

Uppgift 9

Bygg en enkel attackkedja med 3-5 steg.

Svarsinstruktion: Använd tactics som etiketter. Syftet är analys och försvar, inte teknisk genomförandeinstruktion.

1. Initial Access:

En användare får ett trovärdigt nätfiskemejl med en falsk faktura och öppnar den bifogade filen.

Försvar och analys: Här handlar skyddet om att fånga mejlet i ett filter innan det når inkorgen. Om det slinker igenom tittar analytikern efter nätverkslarm som reagerar när office-dokument försöker ansluta till okända externa servrar.

2. Execution:

Dokumentet kör ett dolt skript i bakgrunden som använder datorns inbyggda verktyg för att ladda ner själva skadeprogrammet.

Försvar och analys: Analytikern fokuserar på processloggar från datorn. Övervakningen (EDR-system) måste vara inställd på att larma direkt när ett program som Word eller Excel plötsligt startar PowerShell eller kommandotolken, eftersom det är ett avvikande mönster.

3. Privilege Escalation

Skadeprogrammet utnyttjar att datorn saknar en viss säkerhetsuppdatering för att ge sig själv administratörsbehörighet.

Försvar och analys: Det grundläggande försvaret är snabba rutiner för att uppdatera mjukvara. I loggarna letar analytikern efter händelser där okända processer oväntat begär eller tilldelas högsta systemrättigheter.

4. Impact:

Med full kontroll över systemet börjar programmet kryptera användarens filer för att kräva en ransomware.

Försvar och analys: Här måste övervakningen snabbt fånga upp beteendet att tusentals filer ändras eller byter filändelse på väldigt kort tid, och automatiskt isolera datorn från nätverket. Det absolut viktigaste skyddet är att ha säkra säkerhetskopior som inte går att nå från det vanliga nätverket.

Uppgift 10

Beskriv varje steg i er kedja med “varför”, “hur” och “vad såg vi?”.

Svarsinstruktion: Koppla till TTP-modellen: tactic, technique och procedure.

Steg 1: Falsk faktura

Varför (Tactic: Initial Access): Angriparen vill få in en fot i IT-miljön från utsidan.

Hur (Technique: Phishing - Spearphishing Attachment): De skickar ett falskt mejl med en manipulerad fil och litar på att en stressad medarbetare klickar på den.

Vad såg vi? (Procedure): I mejlserverns loggar syntes ett mejl med ämnesraden "Sen faktura" och en bifogad fil döpt till Faktura_sept.doc. Någon minut senare registrerade klientskyddet att användaren dubbelklickade på filen, vilket startade Microsoft Word.

Steg 2: Den dolda nedladdningen

Varför (Tactic: Execution): Angriparen behöver köra kod på datorn för att kunna ladda ner sina krypteringsverktyg från nätet.

Hur (Technique: Command and Scripting Interpreter): Dokumentet innehåller ett osynligt makro som startar datorns inbyggda terminal för att smälta in bland vanliga systemprocesser.

Vad såg vi? (Procedure): En avvikelse dök upp i processövervakningen. Programmet WINWORD.EXE startade plötsligt powershell.exe med flaggan -Hidden i bakgrunden. Därefter såg brandväggen hur PowerShell omedelbart öppnade en nätverksanslutning mot en okänd IP-adress för att ladda ner en körbar fil (payload.exe).

Steg 3: Ta kontroll

Varför (Tactic: Privilege Escalation): Skadeprogrammet har just nu bara samma begränsade rättigheter som användaren. För att kunna kryptera systemfiler eller stänga av virusskyddet krävs administratörsmakt.

Hur (Technique: Exploitation for Privilege Escalation): Programmet letar upp en äldre, ouppdaterad tjänst på datorn och utnyttjar en känd sårbarhet i den för att tvinga systemet att ge ut högre behörigheter.

Vad såg vi? (Procedure): I Windows säkerhetsloggar registrerades att processen payload.exe oväntat beviljades SYSTEM-rättigheter. Sekunderna efter loggades en händelse om att datorns antivirustjänst inaktiverades.

Steg 4: Kryptering och utpressning

Varför (Tactic: Impact): Det strategiska slutmålet är att störa verksamheten och låsa datan för att kunna kräva lösensumma.

Hur (Technique: Data Encrypted for Impact): Angriparens kod går systematiskt igenom hårddisken, krypterar alla dokument den hittar och lämnar kvar en textfil med instruktioner för betalning.

Vad såg vi? (Procedure): SIEM-systemet larmade om extremt hög diskanvändning. Filövervakningen (FIM) visade en massiv spik där hundratals filer i sekunden döptes om och fick filändelsen .lol, samtidigt som filen README_PAY.txt skapades i varje mapp.

Uppgift 11

Identifiera vilka steg i attackkedjan som är mest osäkra.

Svarsinstruktion: Beskriv vad ni behöver veta mer om för att göra analysen bättre.

Osäkerheten i Privilege Escalation

Vi ser i händelseloggarna att skadeprogrammet oväntat fick SYSTEM-rättigheter och att antivirusprogrammet stängdes av. Osäkerheten ligger i att vi har en blind fläck kring själva intrångets eskalering. Vi vet inte vilken tjänst som utnyttjades. Utan denna information kan vi rensa datorn, men vi vet inte vilket hål vi ska täppa till i nätverket för att stoppa nästa attack.

För att göra analysen bättre behöver vi:

Utökad processövervakning: Data från till exempel Microsoft Sysmon som visar exakt vilka minnesadresser eller andra processer som payload.exe rörde vid innan rättigheterna eskalerades

Uppgift 12

Rita eller beskriv attackkedjan som en enkel kedja från första kontakt till påverkan.

Svarsinstruktion: Använd pilar och korta rubriker. Om ni skriver digitalt kan ni använda tabell eller

punktlista.

Initial Access

(Användaren klickar på virus fakturan i mejlet)

-> Execution

(Word kör ett dolt skript som laddar ner den skadliga koden)

->Privilege Escalation

(Koden utnyttjar en säkerhetslucka för att ta över administratörsrollen)

->Impact

(Filerna låses med kryptering och verksamheten stannar)

Del 4 - Försvarsfrågor och Blue/Purple-perspektiv

Uppgift 13

Formulera minst en försvarsfråga per steg i attackkedjan.

Svarsinstruktion: Exempel: Hur skulle detta kunna upptäckas? Vilken signal, rutin eller kontroll kan vara relevant?

Steg 1: Initial Access (Den falska fakturan)

Hur kunde mejlet passera våra e-postfilter och säkerhetsmekanismer (som SPF/DKIM/DMARC) utan att flaggas eller blockeras?

Har vi tekniska spärrar på plats, exempelvis via Group Policy (GPO), som helt förbjuder Office-dokument från internet att exekvera makron?

Finns det fler användare i organisationen som tagit emot samma fil, och har någon annan klickat på den?

Steg 2: Execution (Den dolda nedladdningen)

Varför tillåter vårt klientskydd (EDR) att vanliga kontorsprogram som Word obehindrat får starta kraftfulla systemverktyg som PowerShell i bakgrunden?

Loggar vi den faktiska koden som körs i minnet , så att vi kan extrahera den specifika webbadressen verktyget laddades ner ifrån?

Har vi nätverksregler som blockerar okända skript från att initiera utgående anslutningar till okända domäner?

Steg 3: Privilege Escalation (Ta över kontrollen)

Vilken exakt sårbarhet eller felkonfiguration utnyttjades för att eskalera till SYSTEM-rättigheter, och varför brast vår patch-hantering på just den här maskinen?

Varför tillät operativsystemet att en okänd process stängde ner vårt antivirusskydd? Saknar vi aktiverat "Tamper Protection" (manipuleringsskydd)?

Steg 4: Impact (Kryptering och utpressning)

Krävs det mänskligt agerande för att koppla bort datorn, eller har vi larmregler som automatiskt isolerar maskinen från nätverket när hundratals filer byter namn per sekund?

Är våra säkerhetskopior (backuper) kryptografiskt skrivskyddade (immutable) och nätverksmässigt isolerade så att angriparens SYSTEM-rättigheter inte räcker för att radera även dem?

Uppgift 14

Välj två tekniker och resonera kring möjliga detektionssignaler.

Svarsinstruktion: Håll svaret på konceptuell nivå. Beskriv typer av signaler, inte tekniska exploit-steg.

Valid Accounts (T1078) – Att använda legitima inloggningsuppgifter

När en angripare loggar in med ett stulet, men giltigt, lösenord kommer säkerhetssystemen till en början att se inloggningen som helt normal. Eftersom lösenordet är rätt finns det ingen "skadlig kod" att upptäcka. Därför måste detektionssignalerna bygga på kontext och avvikelser från ett normalt beteende.

Geografiska och tidsmässiga signaler: Ett starkt larm triggas av fysisk omöjlighet. Om ett konto loggar in från kontoret i Stockholm och sedan 15 minuter senare loggar in från en server i Asien, är signalen stark. Likaså är inloggningar mitt i natten från ett konto som normalt bara används kontorstid en stark varningsklocka.

Beteendemässiga avvikelser: Signalen här är vad kontot gör efter inloggningen. Om ett konto som tillhör kundtjänst plötsligt börjar söka igenom nätverket efter filservrar för företagshemligheter, eller försöker köra administrativa nätverkskommandon, indikerar signalen starkt att personen bakom tangentbordet är en angripare.

Scheduled Task/Job (T1053) – Schemalagda aktiviteter

Angripare använder operativsystemets inbyggda kalenderfunktion för att starta sin bakdörr automatiskt, exempelvis varje gång datorn startas. Eftersom schemaläggaren är en legitim del av operativsystemet måste signalerna fokusera på logiken i vad som schemaläggs.

Proccess agerar konstigt: En tydlig signal är vem som skapar aktiviteten. Det är normalt att ett installationsprogram skapar ett schemalagt jobb, men om en vanlig kontorsapplikation (som Excel) eller ett skript plötsligt ber systemet att schemalägga en framtida händelse, är det en röd flagga.

Sökvägar och filplacering: Signalen ligger i var den schemalagda koden pekar. Legitima systemuppdateringar kör program som ligger i skyddade systemmappar. Om detektionsmotorn ser en schemalagd aktivitet som pekar mot en körbar fil i en tillfällig mapp (som Papperskorgen eller en Temp-katalog), är det en stark signal på att någon försöker gömma kod.

Uppgift 15

Välj två tekniker och resonera kring möjliga riskreducerande åtgärder.

Svarsinstruktion: Beskriv organisatoriska, tekniska eller processmässiga åtgärder.

Phishing: Spearphishing Attachment (T1566) – Riktade nätfiskemejl

Att stoppa skadliga mejl från att komma in i nätverket kräver ett försvar i flera lager, eftersom angriparna ständigt ändrar sina metoder och mål.

Tekniska åtgärder: Grunden är att bygga inbyggda spärrar. Detta inkluderar avancerade e-postfilter som verifierar avsändaren (via SPF, DKIM och DMARC) och skickar misstänkta bifogade filer till en säker isolerad miljö (sandbox) för analys innan de når användaren. På klientnivå kan man tekniskt blockera Office-program från att starta makron eller processer som PowerShell.

Organisatoriska åtgärder: Utbildning och säkerhetskultur är avgörande. Personalen behöver regelbunden och realistisk träning i att känna igen manipulerade mejl. Särskilt utsatta grupper, som ekonomiavdelningen som ofta hanterar externa fakturor, bör få utbildning kring hur riktat nätfiske ser ut.

Processmässiga åtgärder: Det måste vara extremt enkelt att göra rätt. Genom att integrera en "Rapportera misstänkt mejl"-knapp direkt i e-postklienten, kombinerat med en rutin där säkerhetsteamet automatiskt kan dra tillbaka likadana mejl från allas inkorgar så fort en person larmar, minskar risken drastiskt.

OS Credential Dumping (T1003) – Stöld av inloggningsuppgifter från RAM

När angriparen försöker stjäla lösenord och hashar från operativsystemets minne handlar försvaret om att begränsa både behörigheter och tillgången till känslig data.

Tekniska åtgärder: Slå på operativsystemets inbyggda skyddsfunktioner, exempelvis Credential Guard och LSA Protection i Windows. Dessa funktioner isolerar och krypterar den del av RAM där lösenorden lagras, vilket gör att en angripare inte kan läsa ut dem ens med mer avancerade verktyg.

Organisatoriska åtgärder: Implementera principen om "minsta möjliga behörighet" (Least Privilege). För att kunna dumpa lösenord från minnet krävs nästan alltid att angriparen har lokal administratörsåtkomst. Om företaget beslutar att inga vanliga användare får vara administratörer på sina egna kontorsdatorer, elimineras en stor del av risken.

Processmässiga åtgärder: Inför en skiktad administrationsmodell (Tiered Administration). Det innebär stenhårda regler för var nätverksadministratörer får logga in. En domänadministratör ska aldrig få logga in på en vanlig kontorsdator för att ge IT-support. Då säkerställer processen att deras kraftfulla lösenord överhuvudtaget inte finns i RAM på en dator som lättare kan angripas.

Uppgift 16

Beskriv hur ett säkerhetsteam kan använda en attackkedja för att förbättra sitt försvar.

Svarsinstruktion: Skriv 200-300 ord. Ta upp lärande, prioritering och uppföljning.

Strukturerat lärande:

När en attack bryts ner i en tidslinje förstår teamet sammanhanget, inte bara den tekniska händelsen. De ser hur ett klick i ett mejl leder till ett nedladdat skript, som i sin tur leder till stulna lösenord. Detta gör att analytikerna lär sig känna igen angriparens mönster och beteenden, vilket gör det enklare att förutse vad motståndaren kommer att försöka göra framöver.

Effektiv prioritering:

Eftersom en angripare måste lyckas med flera steg i rad för att nå sitt mål, behöver försvaret i teorin bara bryta kedjan på en specifik punkt för att stoppa attacken. Attackkedjan hjälper teamet att rikta resurserna dit de gör störst nytta. Det är ofta betydligt mer effektivt att prioritera hårda tekniska spärrar tidigt i kedjan som t.ex att lägga fokus åt e-postfilter och makron vid Initial Access än att lägga all budget på att försöka stoppa skadan i slutet när angriparen redan har fått administratörsrättigheter.

Kontinuerlig uppföljning:

Kedjan fungerar som ett facit för att utvärdera och förbättra försvaret över tid. Efter en verklig incident eller en simulerad övning kan teamet gå igenom varje steg och ställa frågan: "Såg vi det här steget? Om inte, varför?". Genom att metodiskt justera larmregler, täppa till blind spots och följa upp brister utifrån kedjans faser, säkerställer teamet att försvaret ständigt utvecklas och att samma intrång inte lyckas två gånger.

Del 5 - Källor, spårbarhet och kvalitet

Uppgift 17

Dokumentera vilka källor ni använder i er ATT&CK-analys.

Svarsinstruktion: Skriv minst tre källor eller länkar. Beskriv kort vad varje källa bidrar med.

Officiella MITRE ATT&CK-portalen (attack.mitre.org) - Källan används för att slå upp exakta definitioner av taktiker och tekniker, identifiera vilka hotaktörer som använder dem

MITRE ATT&CK Navigator (mitre-attack.github.io/attack-navigator)- verktyg för att visualisera matrisen. Källan används rent operativt för att genomföra gap-analyser och skapa heatmaps.

SigmaHQ (sigmahq.io / github.com/SigmaHQ) - En öppen standard och plattform för att skriva och dela detektionsregler oberoende av vilket SIEM-system som används (som Wazuh, Splunk eller Elastic).

Uppgift 18

Beskriv hur ni säkerställer att er TTP-mappning är rimlig.

Svarsinstruktion: Ta upp källa, motivering, osäkerhet och gruppgranskning.

För att säkerställa att en TTP-mappning (Tactics, Techniques, and Procedures) är korrekt och håller hög kvalitet i en defensiv analys.

1. Källa (Data och hotrapporter)

Mappningen får aldrig baseras på rena gissningar. Varje teknik som föreslås måste kunna styrkas med riktig data, antingen från organisationens egna insamlade loggar (som SIEM eller EDR) eller från externa, trovärdiga hotrapporter (Threat Intelligence) som beskriver hur angripare faktiskt har betett sig.

2. Motivering (Resonemanget)

Det räcker inte att bara sätta ett ATT&CK-ID på en händelse för att analytikern måste dokumentera varför den passar in. Motiveringen knyter samman det observerade beteendet med ramverkets definition. Om en händelse mappas till Ingress Tool Transfer (T1105) måste motiveringstexten tydligt förklara vilket nätverksflöde eller processmönster som visar att en fil faktiskt laddats ner.

3. Kontextanalys

Eftersom många angrepp använder legitima systemverktyg (som PowerShell eller WMI) finns det alltid en inbyggd osäkerhet kring om ett beteende är skadligt eller legitimt. Analytikern måste värdera osäkerheten öppet. Alternativa förklaringar till händelsen? Kan aktiviteten bero på en administratör som utför underhåll? Om datakvaliteten är bristfällig bör mappningen markeras med en lägre säkerhetsgrad tills mer information kan samlas in.

4. Gruppgranskning (Peer Review)

En av de bättre spärrarna mot felaktiga slutsatser är en kollega. Innan en analys eller gap-analys fastställs, bör en annan analytiker granska mappningen. Gruppgranskningen minskar risken för personlig bias, utmanar analytikerns antaganden och säkerställer att motiveringen håller måttet. Det skapar en högre tillförlitlighet i hela säkerhetsteamets arbete.

Uppgift 19

Skapa en mini-Definition of Done för en färdig hotanalys.

Svarsinstruktion: Lista minst fem kriterier. Kriterierna ska gå att använda av hela gruppen.

1. Bra källor

Alla påståenden och slutsatser i analysen är uppbackade av verifierbar data från organisationens egna loggar, EDR-system eller trovärdiga externa hotrapporter. Inga antaganden görs utan bevis.

2. Korrekt ATT&CK-mappning

Det observerade beteendet har brutits ner och mappats till rätt taktik och teknik, kompletterat med en skriftlig motivering som förklarar varför mappningen är rimlig.

3. Dokumenterad osäkerhet

Analysen redovisar öppet eventuella blinda fläckar, brister i datakvaliteten samt risken för att aktiviteten kan ha en legitim förklaring (false positives).

4. Tydliga rekommendationer

Rapporten stannar inte vid en beskrivning av hotet, utan avslutas med prioriterade åtgärder, såsom förslag på skärpta säkerhetsinstruktioner eller färdiga detektionsregler.

5. Genomförd gruppgranskning

Slutsatserna och TTP-mappningarna har granskats och godkänts av en kollega (peer review) för att säkerställa att analysen håller objektiv standard och friar sig mer från personliga missbedömningar.

Uppgift 20

Beskriv vad som gör en hotanalys användbar för någon annan än den som skrev den.

Svarsinstruktion: Skriv 150-250 ord. Fokusera på tydlighet, spårbarhet och mottagare.

En hotanalys blir verkligen användbar för andra först när den är anpassad efter sina mottagare. Eftersom rapporten läses av alltifrån tekniska analytiker till ledningspersoner, måste den kunna brygga klyftan mellan tekniska detaljer och faktiska risker. En säkerhetschef vill se konsekvenserna och prioriteringarna, medan det operativa teknikteamet behöver exakta spår för att bygga effektiva larm.

För att fungera som ett gemensamt underlag krävs absolut tydlighet. En bra analys undviker onödig tekniskinvecklade förklaringar och förklarar pedagogiskt vad som har hänt, varför angriparen agerar på ett visst sätt och vad organisationen behöver göra. Genom att använda standardiserade ramverk som MITRE ATT&CK talar alla parter samma språk, vilket drastiskt minskar risken för missförstånd.

Slutligen är spårbarhet helt avgörande för att kollegor och andra team ska lita på slutsatserna. Man ska kunna följa det resonemanget hela vägen från grunddata och loggar, via dokumenterade osäkerheter, till de färdiga rekommendationerna. När källor redovisas öppet och varje påstående har en tydlig motivering, förvandlas analysen till ett faktabaserat verktyg som hela organisationen kan samarbeta kring och agera på.

Del 6 - Koppling till backlog, sprint och Workshop 3

Uppgift 21

Uppdatera er backlog baserat på det ni upptäckte i Workshop 2.

Svarsinstruktion: Skriv minst fem nya eller ändrade backlog items. Ge kort motivering.

1. Utöka definition of done: Fler punkter och kriterier

2. Dela backlog-item om inventering i två: Organisationens tillgånger och lista på godkända mjukvaror delades upp
3. Checklista inför workshop 3: struktur
4. TTP tabell: Förberedelse inför kommande projekt.
5. Nästa planering

Uppgift 22

Beskriv hur er attackkedja förhåller sig till ert Sprint Goal.

Svarsinstruktion: Är sprintmålet fortfarande relevant? Behöver något justeras?

Vårt sprint goal var särkildt fokuserat på att bygga upp vårt team och skapa ett tydligare arbetssätt samt struktur.

Uppgift 23

Formulera minst två uppföljningsfrågor inför Workshop 3.

Svarsinstruktion: Frågorna ska kunna användas vid review eller retrospektiv.

1. Har vi nått våra mål

2. Har vårt arbetssätt fungerat eller behöver något ändras

Uppgift 24

Förbered en kort statusrapport till Workshop 3.

Svarsinstruktion: Skriv 5-7 punkter: vad ni gjorde, vad som blev klart, vad som är oklart och vad ni vill ändra.

Vad gick bra:

Mötesplanering gick bra, alla hade hög närvaro, smidigt med att göra checklistor, bra med en board i github.

Vad som blev svårt: Vi hade önskat mer info om projekt för att få ett tydligare mål

Vad vi vill ändra på: Vi tycker att det mesta har fungerat bra och litar på våran egna förmåga att se möjligheterna att förbättras inför kommande utmaningar.

Frivillig fördjupningsutmaning

Skapa en komplett mini-hotanalys baserad på din Workshop 2-kedja.

Inkludera: mål med analysen, attackkedja, TTP-tabell, försvarsfrågor, källor, osäkerheter, uppdaterad backlog och förslag till nästa sprint. Max tre sidor.

Rekommenderade referenser

- MITRE ATT&CK: https://attack.mitre.org/
- MITRE ATT&CK Enterprise Matrix: https://attack.mitre.org/matrices/enterprise/
- CISA - Best Practices for MITRE ATT&CK Mapping: https://www.cisa.gov/news-events/news/best-practices-mitre-attckr-mapping
- MITRE ATT&CK Data & Tools: https://attack.mitre.org/resources/attack-data-and-tools/

Bedömningskriterier

Bedömningen fokuserar på analysförmåga, begreppsanvändning, spårbarhet, defensivt perspektiv och koppling till projektarbete.

Matrisen är formulerad med kursens nivåer Godkänt (G) och Väl godkänt (VG). Den mellersta kolumnen beskriver kvaliteter som stärker bedömningen inom godkänd nivå och kan användas som stöd i återkoppling.

Bedömningsområde	Grundläggande krav för G	Tydliga kvalitetskännetecken	Kvalitetskännetecken för VG
Förståelse för MITRE ATT&CK	Kan beskriva ATT&CK på en grundläggande nivå och visar förståelse för ramverkets syfte.	Förklarar ATT&CK med egna ord och kopplar ramverket till hotanalys och säkerhetsarbete.	Visar fördjupad förståelse för ATT&C som analysramverk och resonerar kring styrkor, begränsningar och användningsområden.
TTP-förståelse	Kan identifiera tactic, technique och procedure samt beskriva skillnaden översiktligt.	Använder TTP-begreppen konsekvent och förklarar sambanden mellan dem.	Använder TTP som ett naturligt analysverktyg och kan motivera val samt alternativa tolkningar.
Attackkedjor	Har skapat en enkel attackkedja där stegen följer en logisk ordning.	Attackkedjan är väl motiverad och sambanden mellan stegen förklaras.	Analysen visar systemsyn och används för att resonera kring risker och försvarsperspektiv.
Försvarsfrågor	Har formulerat relevanta försvarsfrågor.	Försvarsfrågorna är välformulerade och kopplas till upptäckt, begränsning eller uppföljning.	Kopplar angriparbeteenden till flera möjliga försvarsperspektiv och resonerar kring prioritering.
Källor och spårbarhet	Anger källor och referenser till analysunderlaget.	Motiverar hur källorna används och visar förståelse för spårbarhet.	Reflekterar kring källornas styrkor oc begränsningar och håller hög dokumentationskvalitet.
Projektarbete	Har uppdaterat backlog eller projektunderlag.	Kopplar analysen till Sprint Goal, backlog eller Definition of Done.	Visar hur analysen skapar värde i projektet och resonerar kring prioritering, risk och nästa steg.

Samlad bedömning

Godkänt (G)
Studenten har genomfört huvuddelen av uppgifterna, visar grundläggande förståelse för ATT&CK, kan beskriva en enkel attackkedja, kan formulera relevanta försvarsfrågor och kan dokumentera sitt arbete.

Väl Godkänt (VG)
Studenten visar god analytisk förmåga, använder ATT&CK och TTP konsekvent, motiverar sina slutsatser, identifierar osäkerheter, visar god förståelse för försvarsperspektivet och kopplar analysen till projektets mål och arbetssätt.